中间人攻击-ARP 欺骗

一、攻击基本原理

1、利用 ARP 协议的漏洞

2、ARP 协议原理：

局域网内交换机是二层设备，只认识 mac，只检查帧头 mac

已知 IP 解析 mac 地址

1）(圈发)发送 ARP 广播请求：

我是 10.1.1.1 ，我的 MAC 是 AA

FF AA 谁是 10.1.1.3 ，你的 MAC 是？？

2）（小琴）发送 ARP 单波应答，

CC AA 谁是 10.1.1.3 ，你的 MAC 是 CC

MAC 与 IP 存储在 ARP 缓存表，谁的应答后到达，缓存表就存谁，交换机只检查 MAC

3）ARP 是网络层协议

问题：圈发和小琴没有互相访问。子菲能否实现对二者的攻击

子菲可以通过 ARP 发送广播报文：我是 10.1.1.1 我的 mac 是 BB

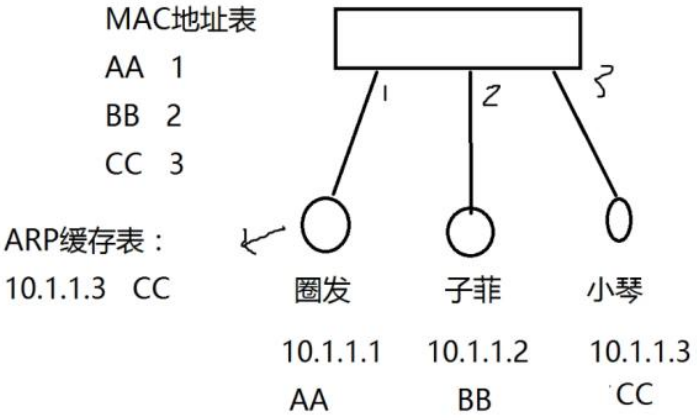
ARP 只记录应答，但是不能做身份验证，容易出现身份验证漏洞

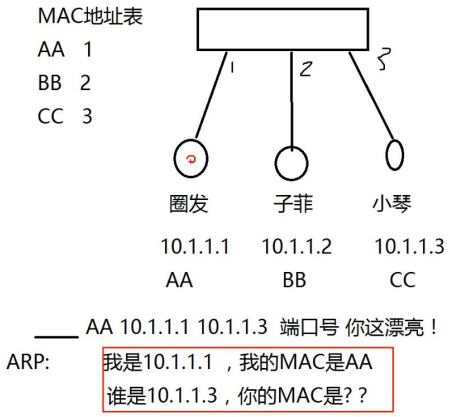
3、ARP 攻击原理

攻击人通过发送虚假的 arp 应答实现 arp 缓存投毒！而受害人没有办法进行身份（真伪）验证！

中间人攻击原理

1. 利用的ARP协议的漏洞
2. ARP协议原理
   1）发送ARP广播请求
   2）发送ARP单播应答





二、ARP 和 DNS 欺骗实验

参考网址：https://www.cnblogs.com/cll-wlaq/p/17855651.html

2.1 实验目的

1. 了解 ARP 欺骗和 DNS 欺骗的原理

2. 掌握常见工具（ettercap）的使用

注意：本实验在虚拟机上面进行，不准用于破坏他人计算机环境或诱导他人下载木马，本实验仅做学习交流，禁止一切非法行为，否则后果自负！

2.2 实验环境

Kali 、windows10

2.3 实验工具

EtterCap 扫描工具

VMware 上安装的攻击主机 kali 一台

VMware 上安装的靶机 win10 一台

2.4 实验步骤

1、准备工作

（1）打开攻击机 kali 和靶机 win10，关闭 win10 的防火墙。

（2）查看攻击机 kali 和靶机 win10 的 IP，并确保两台机器处于同一局域网段且互相 ping 通。

```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 1500
        inet 192.168.101.130  netmask 255.255.255.0  broadcast 192.168.101.255
        inet6 fe80::f12d:163a:28fd:4b62  prefixlen 64  scopeid 0x20<link>
        ether 00:0c:29:f3:e2:a0  txqueuelen 1000  (Ethernet)
        RX packets 44692  bytes 6799386 (6.4 MiB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 47238  bytes 3218085 (3.0 MiB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0
```

（3）打开 kali 的 Apache 服务

使用管理员账户输入以下命令：

1）开启 apache 服务：service apache2 start

```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# service apache2 start
```

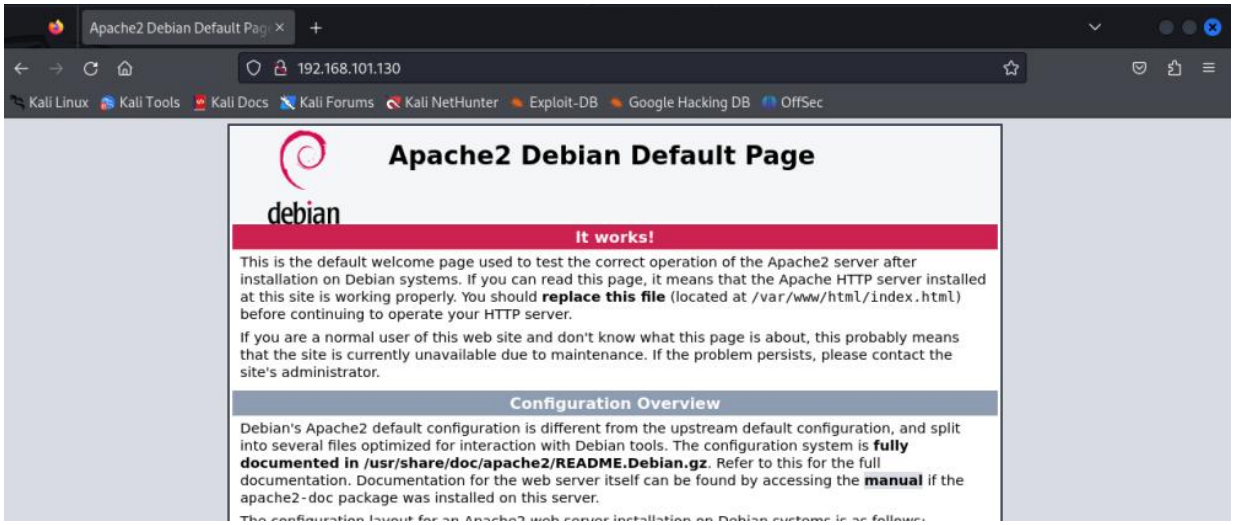
2）查看服务状态：service apache2 status

```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# service apache2 status
● apache2.service - The Apache HTTP Server
     Loaded: loaded (/usr/lib/systemd/system/apache2.service; disabled; preset: disabled)
     Active: active (running) since Tue 2025-10-07 11:51:47 EDT; 16s ago
       Docs: https://httpd.apache.org/docs/2.4/
    Process: 110894 ExecStart=/usr/sbin/apachectl start (code=exited, status=0/SUCCESS)
   Main PID: 110910 (apache2)
      Tasks: 6 (limit: 2262)
     Memory: 19.4M (peak: 19.9M)
        CPU: 124ms
     CGroup: /system.slice/apache2.service
             ├─110910 /usr/sbin/apache2 -k start
             ├─110913 /usr/sbin/apache2 -k start
             ├─110914 /usr/sbin/apache2 -k start
             ├─110915 /usr/sbin/apache2 -k start
             ├─110916 /usr/sbin/apache2 -k start
             └─110917 /usr/sbin/apache2 -k start

Oct 07 11:51:47 kali systemd[1]: Starting apache2.service - The Apache HTTP Server...
Oct 07 11:51:47 kali apachectl[110909]: AH00558: apache2: Could not reliably determine the server's fully qualif>
Oct 07 11:51:47 kali systemd[1]: Started apache2.service - The Apache HTTP Server.
```

4）查看网站服务是否打开，打开浏览器，输入本机

IP



2、ARP 欺骗

（1）清除 win10 的 arp 缓存（arp -d）和查看 arp 表（arp -a）， 可以看到默认网关（192.168.162.129）的物理地址。

```
C:\>arp -d

C:\>arp -a

接口: 192.168.101.201 --- 0x2
  Internet 地址         物理地址              类型
  192.168.101.2         00-50-56-e8-66-ca     动态
  192.168.101.254       00-50-56-f3-7c-6b     动态
  224.0.0.22            01-00-5e-00-00-16     静态
  224.0.0.251           01-00-5e-00-00-fb     静态
  224.0.0.252           01-00-5e-00-00-fc     静态
  239.255.255.250       01-00-5e-7f-ff-fa     静态

C:\>ipconfig

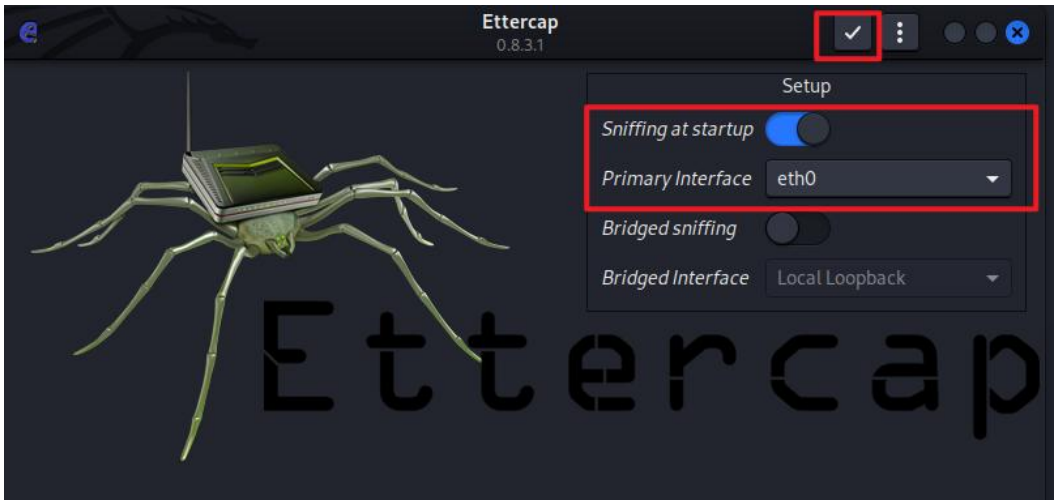
Windows IP 配置


以太网适配器 Ethernet0:

   连接特定的 DNS 后缀 . . . . . : localdomain
   本地链接 IPv6 地址. . . . . : fe80::15f9:dadf:f644:f9b5%2
   IPv4 地址 . . . . . . . . . . . . : 192.168.101.201
   子网掩码 . . . . . . . . . . . . : 255.255.255.0
   默认网关. . . . . . . . . . . . . : 192.168.101.2
```

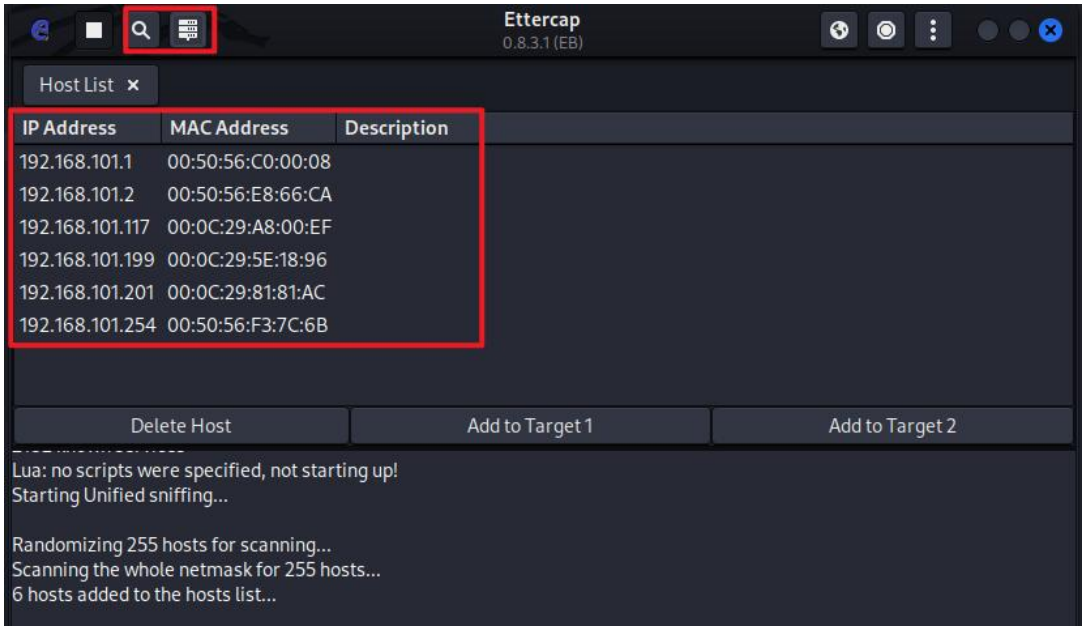
（2）在 kali 虚拟机上打开 etterdcap，打开嗅探功能，设置网卡，进入应用。

```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# ettercap -G
```

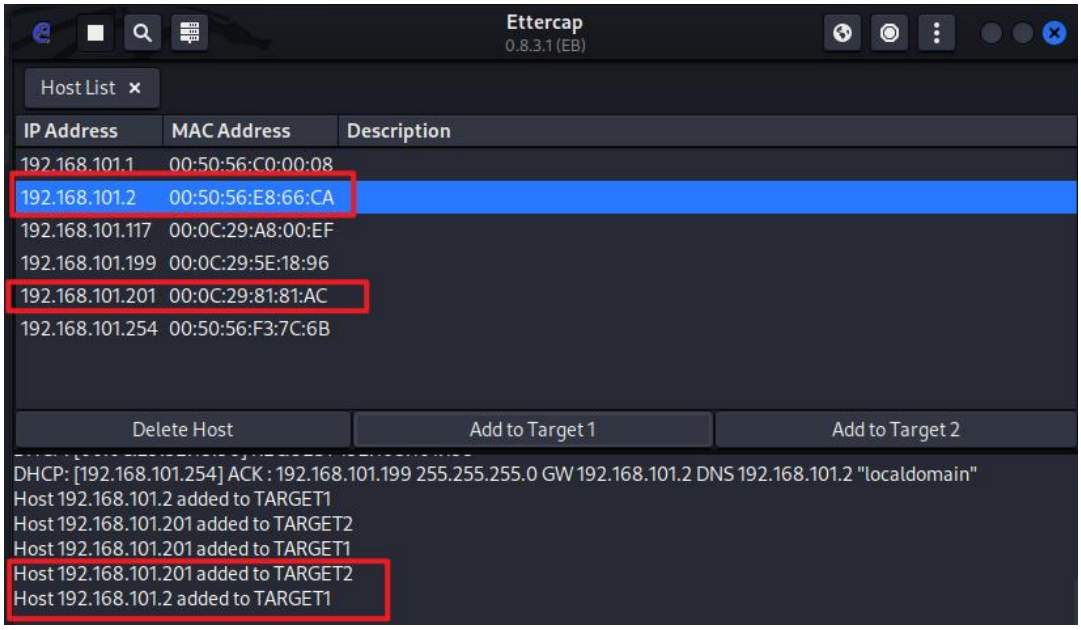




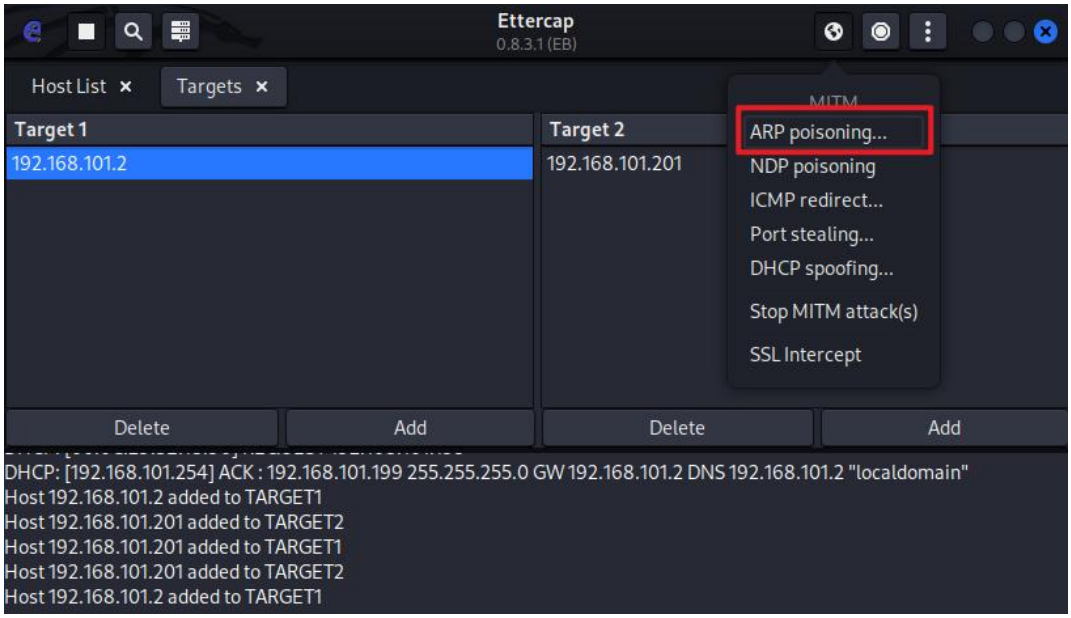
（3）点击左上角🔍，扫描该网段的所有主机信息，在 host list 中查看扫描结果。

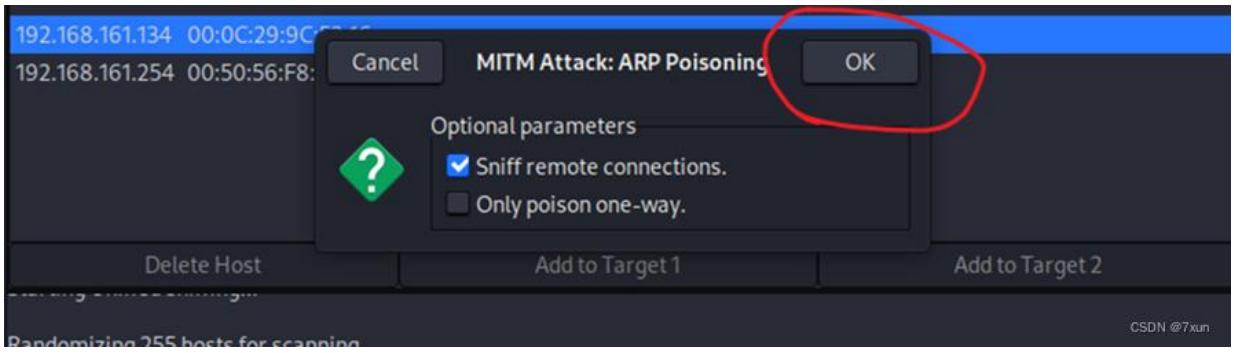


（4）选中欺骗的 IP 主机（win10）和网关，右键，将这两个 IP 分别加入 target

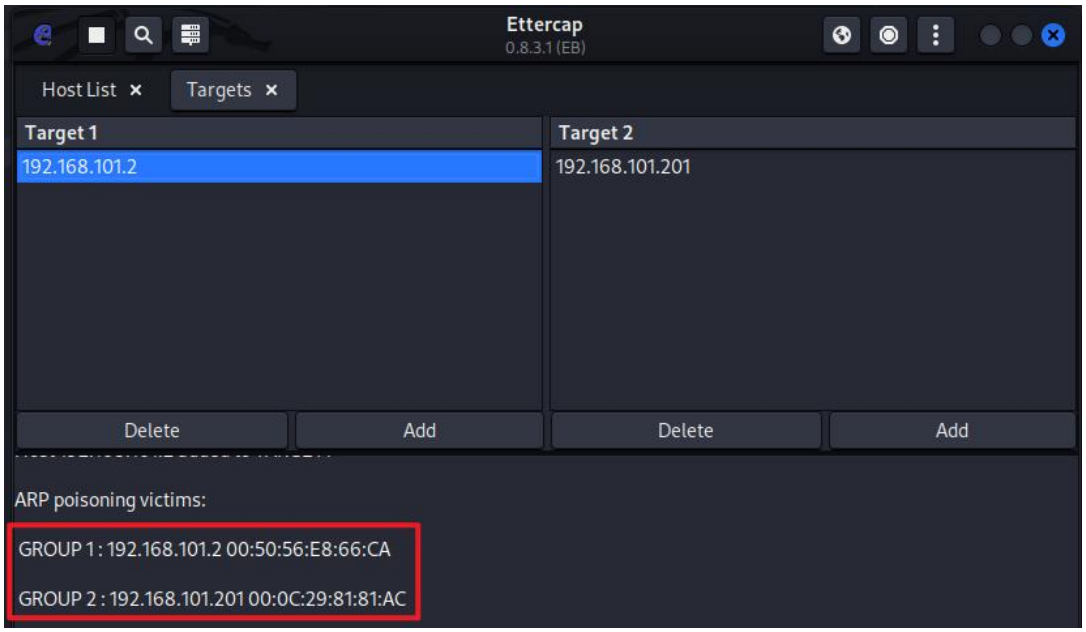


（5）在 MITM 菜单中选择 ARP Poisoning，点击 ok 开始攻击：



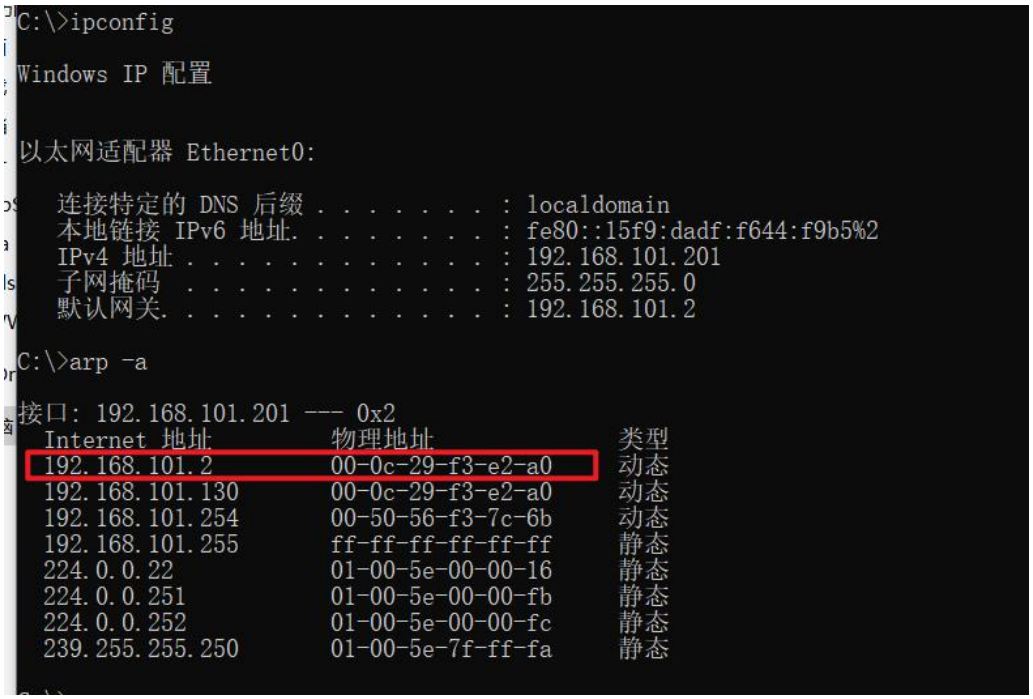


出现以下提示说明 ARP 包成功发送



（6）查看被攻击主机（win10）的 ARP 表

（7）在 win10 上输入 arp -a，可以看到默认网关的地址被更新为攻击机（kali）的 MAC 地址。



在被攻击机（win10）上访问网站。如我们向 zbvc 发送一个 ICMP 的数据包

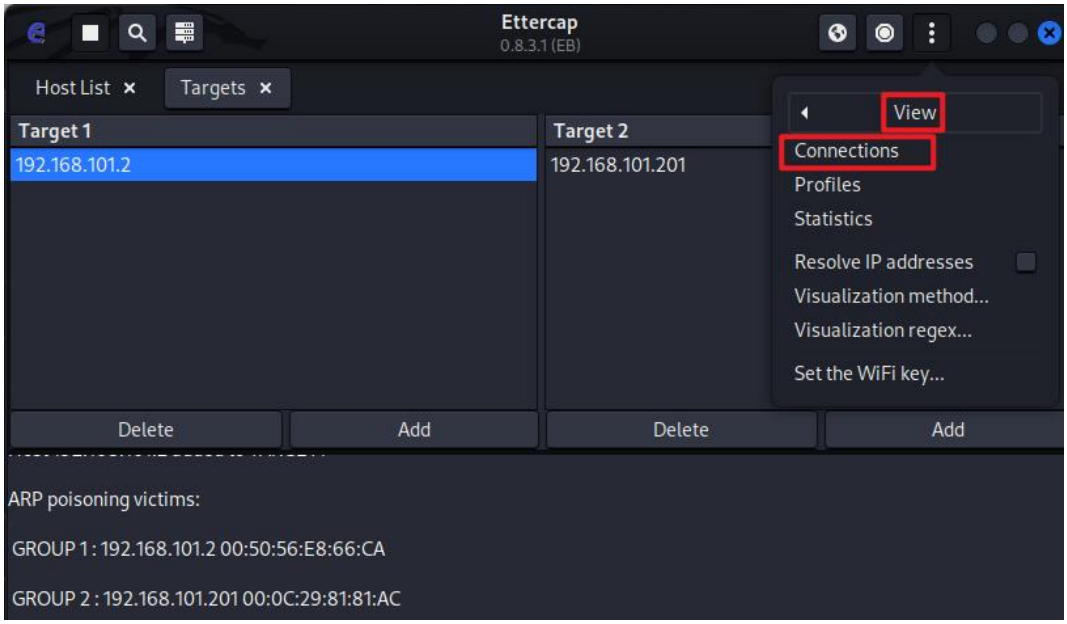
```
C:\>ping www.zbvc.edu.cn

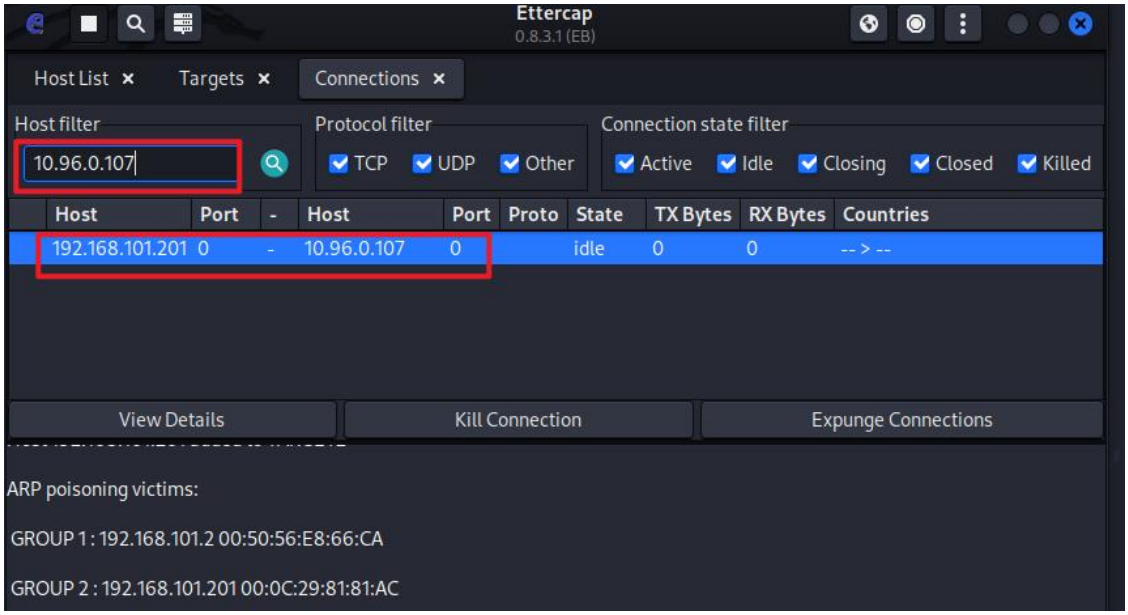
正在 Ping www.zbvc.edu.cn [10.96.0.107] 具有 32 字节的数据:
来自 10.96.0.107 的回复: 字节=32 时间=23ms TTL=128
来自 10.96.0.107 的回复: 字节=32 时间=44ms TTL=128
来自 10.96.0.107 的回复: 字节=32 时间=37ms TTL=128
来自 10.96.0.107 的回复: 字节=32 时间=24ms TTL=128

10.96.0.107 的 Ping 统计信息:
    数据包: 已发送 = 4, 已接收 = 4, 丢失 = 0 (0% 丢失),
往返行程的估计时间(以毫秒为单位):
    最短 = 23ms, 最长 = 44ms, 平均 = 32ms
```

查看结果方式

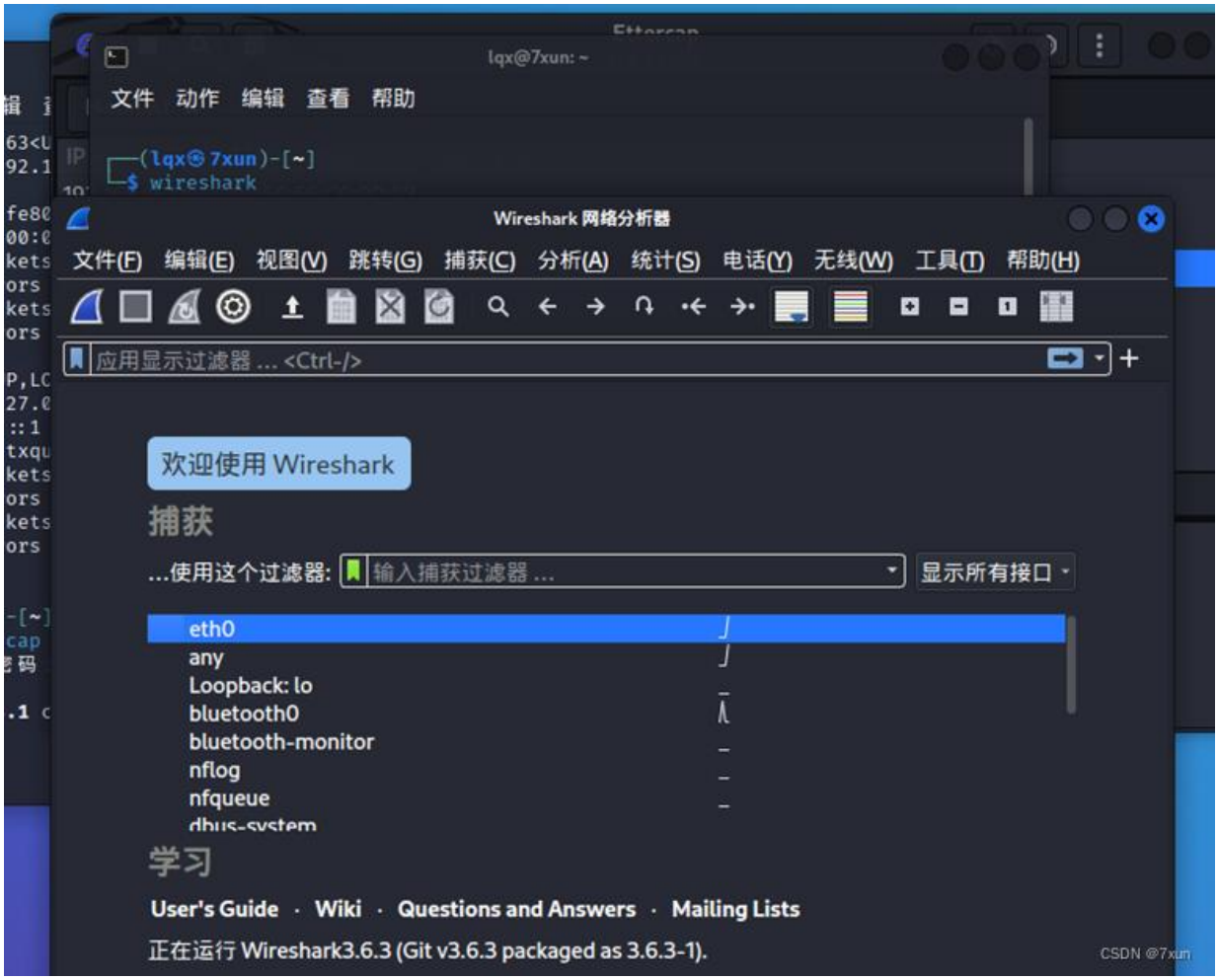
（1）在攻击机上进行查看。如下图，查看嗅探的结果。可以看到，靶机对 zbvc 网站发送的 ICMP 包被转发到攻击机上，被攻击机窃听。

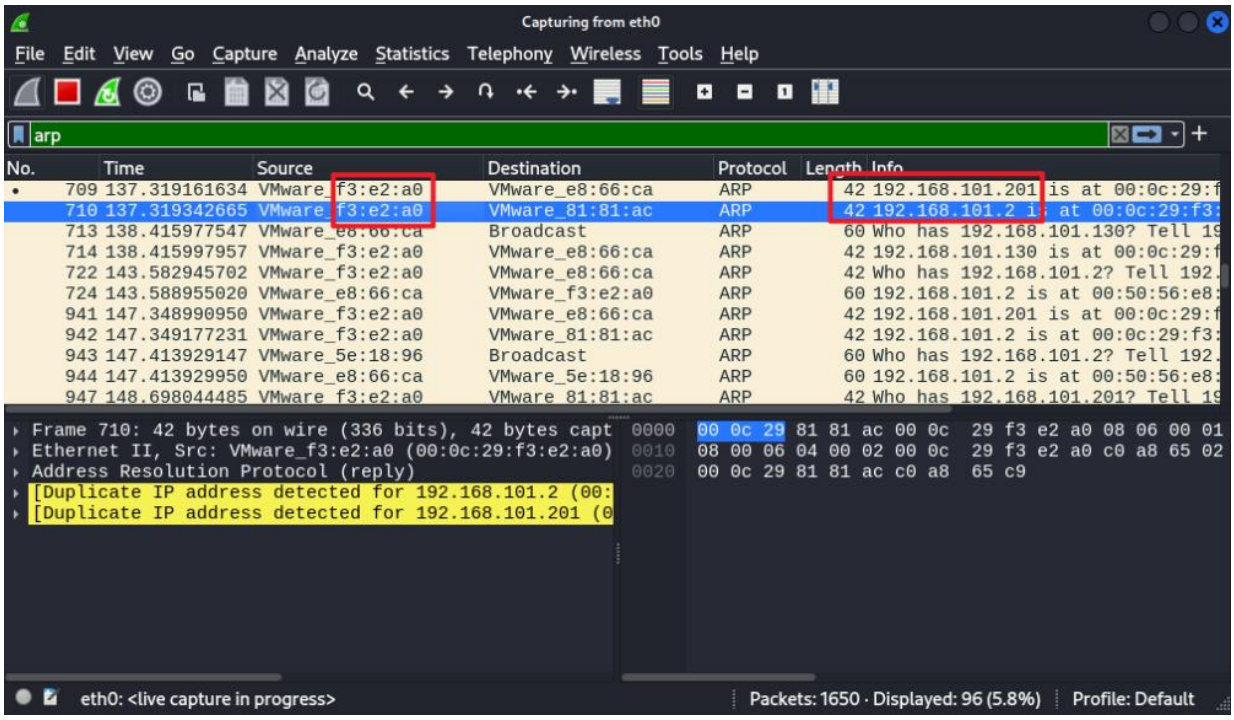




（2）也可以用 wireshark 查看数据包

在 Kali 中打开新命令行，输入 wireshark 运行并抓包，在过滤器中输入 arp 检索出所有 ARP：





进行 arpspoof 实现断网攻击：

参考：

https://blog.csdn.net/qq_54780911/article/details/121891827



取消劫持：ctrl+z 或者 ctrl+c

ettercap 截取账号密码：

借助于 EtterCap 嗅探软件，渗透测试人员可以检测网络内明文数据通讯的安全性，及时采取措施，避免敏感的用户名/密码等数据以明文的方式进行传输。在命令行输入：ettercap -Tq -i eth0-T 是 --text，文本模式；-q 是 --quiet，安静，不显示包的内容。

driftnet 工具捕获目标浏览的图片

如果没有就进行安装：

```
apt install driftnet
```

```
driftnet -i eth0
```

网络安全实验之《ARP 欺骗攻击》实验报告_arp 欺骗实验

https://www.cnblogs.com/half-dragon-little-blue/articles/17644915.html

https://2048ai.net/682ad8fe606a8318e8575600.html?spm=1001.2101.3001.6661.1&utm_medium=distribute.pc_relevant_t0.none-task-blog-2%7Edefault%7EOPENSEARCH%7Eactivity-1-143635236-blog-121891827.235%5Ev43%5Epc_blog_bottom_relevance_base9&depth_1-utm_source=distribute.pc_relevant_t0.none-task-blog-2%7Edefault%7EOPENSEARCH%7Eactivity-1-143635236-blog-121891827.235%5Ev43%5Epc_blog_bottom_relevance_base9&utm_relevant_index=1

实验总结

通过本次实验，我认识到 ARP 攻击就是通过伪造 IP 地址和 MAC 地址实现欺骗的一种攻击手段。攻击者通过伪装自己的 MAC 地址来欺骗目标设备，使其将网络数据包发送到错误的物理地址，从而将流量重定向到攻击者控制的位置。这种攻击可用于中间人攻击、数据窃取或网络干扰，因此在管理时需要采取防范措施，如网络监控和使用安全工具，来检测和防御 ARP 欺骗攻击，以确保网络的安全性和可靠性。使用 ARP 攻击，攻击者可以轻松地拦截、篡改或窃取网络流量，对目标设备进行数据间谍操作。然而，**ARP 欺骗也容易被检测到，而且在伪装 MAC 地址的过程中，攻击者需要在目标网络上产生不稳定性，容易引起怀疑。此外，ARP 欺骗攻击通常需要本地网络访问权限，因此无法用于跨互联网的攻击，存在一定的缺陷**。想要**防御 ARP 欺骗可以使用网络防火墙、网络监控工具和安全认证措施**。网络管理员可以配置网络设备以限制 ARP 流量，实施静态 ARP 条目，或使用 ARP 监控工具来检测异常 ARP 请求和响应。此外，强制双因素身份验证、使用虚拟专用网络（VPN）以及定期更新操作系统和网络设备的软件也可以增强网络的安全性，减少 ARP 欺骗风险。